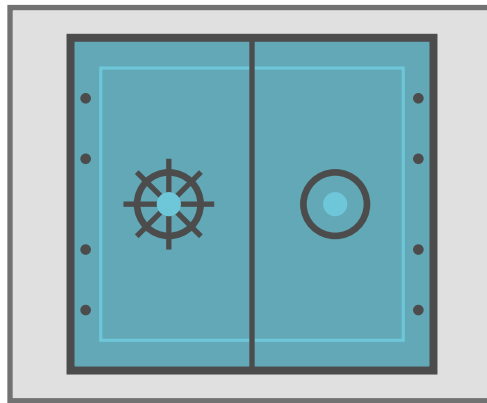


Criptografía y Seguridad

Seguridad en la empresa

Protección de datos



Apunte integral — Teoría

Clase 11 · Última clase de la materia

Instituto Tecnológico de Buenos Aires (ITBA)

Documento elaborado a partir de la transcripción de la clase teórica (Prof. Leandro Suárez) y de las diapositivas oficiales. No se agregó contenido externo al material de clase.

Índice

1. Introducción: el problema	2
1.1. El escenario que motiva todo	2
2. El ciclo de protección de la información	2
3. Gobierno (Data Governance)	3
3.1. El ciclo de vida del dato (Data life cycle)	4
4. Regulaciones (externas e internacionales)	4
4.1. Regulación local: Ley 25.326 (Argentina)	4
4.2. Regulaciones internacionales	5
5. Data Roles (roles sobre los datos)	6
6. Descubrimiento (Discovery)	6
6.1. Clasificación de los datos	7
6.2. El mismo dato en distintos estados	7
6.3. Data Inventory	8
6.4. Data Labeling (etiquetado)	8
7. Protección (Protect)	9
7.1. Enforcement en tiempo de compilación (Compiler-time)	9
7.2. Encriptación de datos en reposo (at-rest)	10
7.3. Encriptación de datos en tránsito (in-transit)	12
7.4. Enforcement en tiempo de ejecución (Execution-time)	12
7.5. Encriptación en memoria	12
7.6. Homomorphic Encryption	13
7.7. Encriptación en SoC / IoT / sistemas embebidos	13
8. Cumplimiento (Comply)	13
8.1. Retención de datos	14
9. Detección (Detect): Data Loss Prevention (DLP)	14
9.1. DLP hoy en día	15
10. Respuesta (Respond): respuesta a incidentes	15
10.1. Qué hacer en las primeras 24 horas	15
10.2. Más allá de las 24 horas	16
11. Cierre y mapa mental	16

1 Introducción: el problema

Esta es la **última clase de la materia** y conecta directamente con la anterior (*Seguridad en la empresa*). El tema se mira desde la perspectiva de un **CISO** (*Chief Information Security Officer*): el director de seguridad de la organización, la persona encargada de velar por la seguridad de la empresa y que, generalmente, tiene **implicancias legales** si se produjera un incidente de seguridad severo con consecuencias jurídicas.

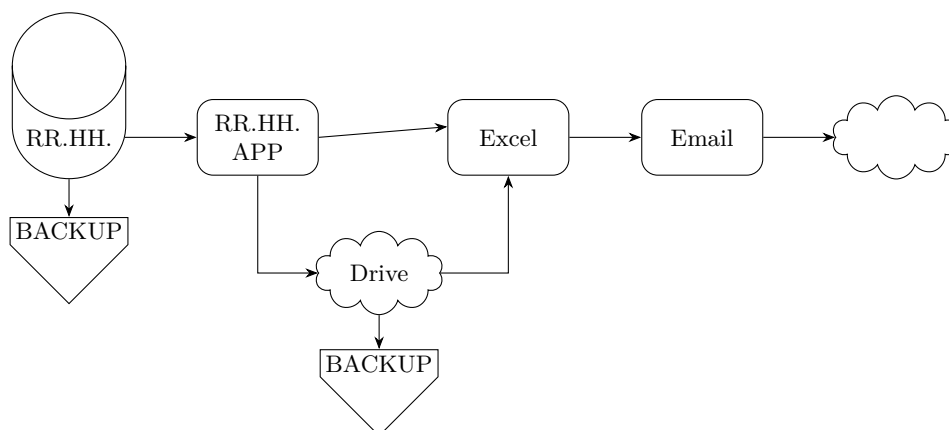
“Acá es donde pasamos a aplicar, digamos, para la protección de datos se pasa a aplicar todos los principios que ya vimos en pos de proteger la CIA: la confidencialidad, integridad y disponibilidad de los datos.”

— Prof. Leandro Suárez (clase teórica)

1.1 El escenario que motiva todo

En una empresa se define una **política de protección de datos personales** que dice: *«Un empleado no puede acceder a ver los sueldos de otros empleados.»*

El profesor plantea el problema como disparador: *¿dónde habría que poner controles para proteger esa información?* La respuesta no es trivial, porque el mismo dato (la planilla de sueldos) se replica y viaja por muchísimos lugares. La diapositiva muestra un diagrama de flujo del dato que conviene tener presente durante toda la clase: un dato «sensible» no vive en un solo lugar.



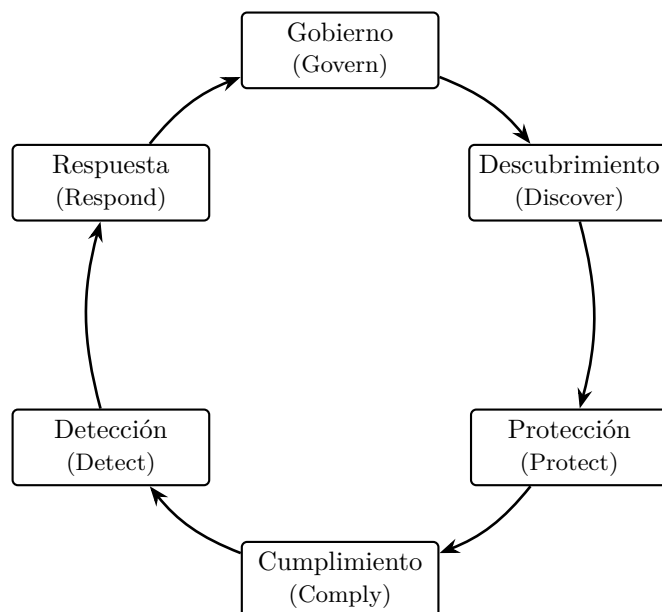
El mismo dato sensible se copia en una base, una app, backups, una hoja de cálculo, un Drive, un mail y la nube.

Idea central de la clase

Los **controles de acceso** de un sistema son parte de la solución, **pero no son suficientes**. El dato escapa del sistema (se exporta a un Excel, se sube a Drive, se manda por mail, se respalda en backups), y en cada uno de esos lugares hay que protegerlo. Por eso se necesita un enfoque integral: el *ciclo de protección de la información*.

2 El ciclo de protección de la información

La materia vuelve sobre la idea de los **ciclos** en seguridad. La protección de la información se organiza como un ciclo de seis etapas que se repite indefinidamente.



1. **Gobierno (Govern):** el punto de *gestión*, donde se toman las decisiones y se define cómo se ejecuta todo. (Es lo visto en la clase anterior, *Seguridad en la empresa*.)
2. **Descubrimiento (Discover):** ver qué datos hay en el universo de datos de la organización.
3. **Protección (Protect):** definir cómo y qué datos se protegen (no todos los datos son sensibles).
4. **Cumplimiento (Comply):** asegurar que esa protección se cumple efectivamente.
5. **Detección (Detect):** ser capaces de detectar filtraciones o brechas de la información.
6. **Respuesta (Respond):** responder a esas filtraciones y evitar que se sigan produciendo.

Y luego se vuelve a empezar: “Y luego volvemos a empezar. Es un ciclo.”

— Prof. Leandro Suárez (clase teórica)

El resto del apunte recorre el ciclo etapa por etapa.

3 Gobierno (Data Governance)

Data Governance

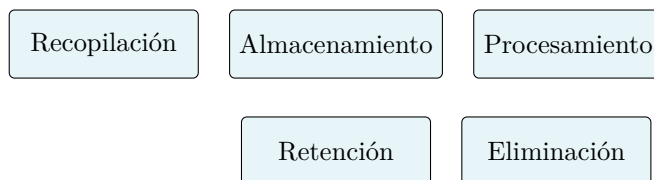
Son **todas las tareas que se realizan para asegurar que los datos sean seguros, estén íntegros, sean confidenciales y estén disponibles** en todo momento que se requiera. Incluye:

- las medidas que deben tomar las **personas**,
- los **procesos** que deben seguir,
- la **tecnología** que los respalda,

durante todo el **ciclo de vida de los datos**. También **define los roles** dentro de la organización para el uso de la información.

Como los sistemas, los datos también tienen un ciclo de vida. Hay normativas que obligan a que los datos vivan cierta cantidad de tiempo, que se borren o que no se borren; y casos en los que se deben eliminar datos por cuestiones legales.

El gobierno de datos establece **estándares internos** (conocidos como **políticas de datos**) que se aplican a cinco actividades sobre los datos:



3.1 El ciclo de vida del dato (Data life cycle)

La diapositiva lo presenta como un ciclo de 5 fases:

1. **Create & collect** — recolección de información a través de todos los canales disponibles.
2. **Store & transmit** — almacenamiento y transmisión de lo recolectado para su procesamiento (a través de sistemas IT, archivado físico y transporte).
3. **Use & distribute** — procesamiento de la información y distribución interna.
4. **Retain** — retención de la información procesada por posibles usos y requerimientos legales/regulatorios.
5. **Dispose and destroy** — disposición/destrucción de la información una vez que vence el período de retención.

¿Por qué importa el ciclo de vida?

“Tener datos en el fondo es tener información, es tener activos importantes que buscan los atacantes muchas veces.”

— Prof. Leandro Suárez (clase teórica) Por eso conviene gestionar cuándo y cuánto viven los datos: cuanto más datos sensibles se conservan sin necesidad, mayor es la superficie de ataque.

4 Regulaciones (externas e internacionales)

El gobierno de datos está condicionado por regulaciones que la organización debe cumplir.

4.1 Regulación local: Ley 25.326 (Argentina)

La **Ley 25.326 de Protección de Datos Personales** aplica a todo sistema que opera en Argentina. La clase resaltó dos artículos:

Artículo 1º (Objeto). «La presente ley tiene por objeto la protección integral de los datos personales asentados en archivos, registros, bancos de datos, u otros medios técnicos de tratamiento de datos, sean éstos públicos, o privados destinados a dar informes, para garantizar el derecho al honor y a la intimidad de las personas, así como también el acceso a la información que sobre las mismas se registre, de conformidad a lo establecido en el artículo 43, párrafo tercero de la Constitución Nacional.»

Artículo 9º (Seguridad de los datos). 1. «El responsable o usuario del archivo de datos debe adoptar las medidas técnicas y organizativas que resulten necesarias para garantizar la seguridad y confidencialidad de los datos personales, de modo de evitar su adulteración, pérdida, consulta o tratamiento no autorizado, y que permitan detectar desviaciones, intencionales o no, de información, ya sea que los riesgos provengan de la acción humana o del medio técnico utilizado.» 2. «Queda prohibido registrar datos personales en archivos, registros o bancos que no reúnan condiciones técnicas de integridad y seguridad.»

¿Qué es un dato personal?

Es todo lo que permite **identificar a una persona** sólo por ese mismo dato. Ejemplos: nombre y apellido, dirección de correo, número de documento, dirección del domicilio.

El nombre es un caso de borde: un nombre muy común (muchos «Leandro Suárez») casi no identifica, mientras que uno único (p. ej. «Lionel Messi») sí. Igualmente, las leyes lo consideran dato personal por el caso particular en que sí es identificable.

Lo importante de esta ley (según el profe)

La ley **no especifica una tecnología**: te dice «a grandes rasgos, hacé todo lo posible para que estos datos permanezcan íntegros y confidenciales y evitá filtraciones o borrados no intencionales». Esto es bueno: al no atarse a una tecnología (la ley es de los años 80), **sigue siendo aplicable hoy**.

Consecuencia práctica: si tu aplicación guarda datos personales, hay que **asesorarse legalmente**. Y este tipo de leyes suele dar a las personas el derecho a *ver* qué datos guarda la organización, *modificarlos* e incluso *pedir su borrado* (el «**derecho al olvido**»). Es algo que se exige en casi todo el mundo (Facebook, Twitter, etc., permiten descargar tu historial y borrar tu cuenta).

4.2 Regulaciones internacionales

HIPAA	<i>Health Insurance Portability and Accountability Act of 1996</i> . Protección de datos relacionados con la salud de las personas (PHI / PPI). Surge de acá la anonimización de los datos médicos (ver más abajo).
GDPR	<i>General Data Protection Regulation</i> . La más conocida de protección de datos personales; de la Unión Europea, aplicada en 2018 .
PCI-DSS	<i>Payment Card Industry Data Security Standard</i> . Regula el uso de información de tarjetas de crédito. Obligatorio para cualquier empresa que quiera operar con tarjetas.
SOX	<i>Sarbanes-Oxley Act</i> (ley federal de EE.UU., 2002). Para empresas que cotizan en bolsa / públicas; exige transparencia en sus operaciones.
FFIEC	<i>Assessment Tool</i> . Framework (hoy algo en desuso).
FDA	<i>Cybersecurity</i> . Consideraciones de ciberseguridad de la <i>Food and Drug Administration</i> (estudios médicos, alimentos y drogas).

GDPR y las cookies. Por esta ley (2018) apareció «de golpe» el tema de los banners de cookies: GDPR pide un **consentimiento explícito** del usuario. Por eso los sitios te dejan elegir «solo lo esencial» (lo necesario para que el sitio funcione) y rechazar las demás (marketing y similares, que registran tus preferencias/actividad e incluso pueden acceder a cookies de terceros). Aplica aunque el sistema esté en Argentina, siempre que haya usuarios o infraestructura en la Unión Europea.

PCI-DSS: dos conceptos clave que impuso

1) Acotar la cantidad de datos a proteger según su criticidad. PCI definió que los datos críticos de una tarjeta son básicamente **5**: número de tarjeta, nombre del titular, vencimiento, código de seguridad (el más crítico) y datos de la banda magnética/chip (a veces, un *PIN* que funciona como segundo factor en el POS). Al acotar a esos ~5 datos, la norma da un *blueprint*: concentrarse en proteger lo realmente sensible y no «todo». “Una

de las cosas más importantes a la hora de proteger datos es acotar la cantidad de datos en base a su criticidad.”

— Prof. Leandro Suárez (clase teórica)

2) Tokenización. La tarjeta (sus 5 datos) se guarda «bajo 7 llaves» en una base muy protegida y segmentada; el sistema opera con un **token** que apunta a esos datos. Si se filtrara el token, no tiene valor por sí mismo: habría que ir a buscar los datos a la base recontra-protegida. Así se desacopla la operación de los datos sensibles.

HIPAA: anonimización

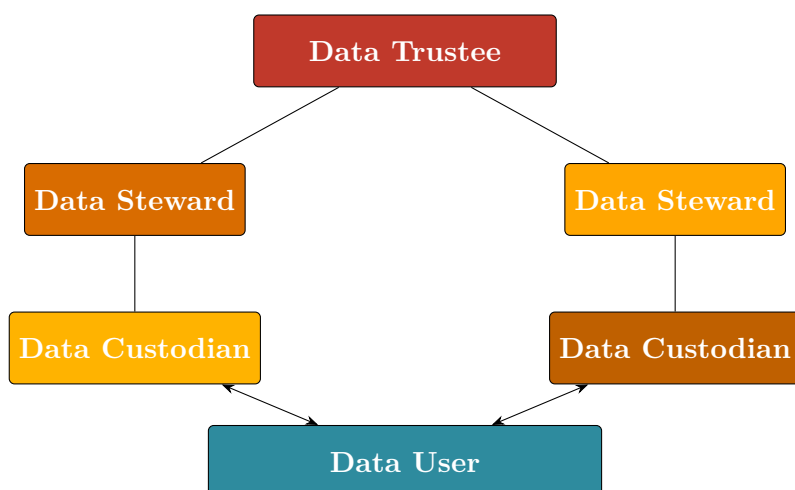
Con HIPAA surgió el concepto de **anonimizar** los datos médicos. La idea: se pueden seguir usando los datos para análisis y búsqueda de patrones, pero *sin saber de quién es cada dato*.

“Yo no sé de quién es este estudio, yo no sé de quién es esta enfermedad.”

— Prof. Leandro Suárez (clase teórica) Esto se suele exigir para historias clínicas.

5 Data Roles (roles sobre los datos)

Para distribuir la responsabilidad sobre los datos se define una **jerarquía de roles**. A medida que se baja en la jerarquía, el dominio de datos que maneja cada interviniente es cada vez más chico.



Data Trustee. Posición estratégica alta (nivel *cabinet*), **responsable legalmente** por los datos. Si pasa algo con esos datos, es el responsable a nivel jurídico.

Data Steward. Responsable interno que **aprueba accesos** a los datos sensibles/restringidos *dentro de su dominio*.

Data Custodian. Autorizado por un Steward para **otorgar (grant) acceso** a los usuarios sobre elementos del dominio del Steward.

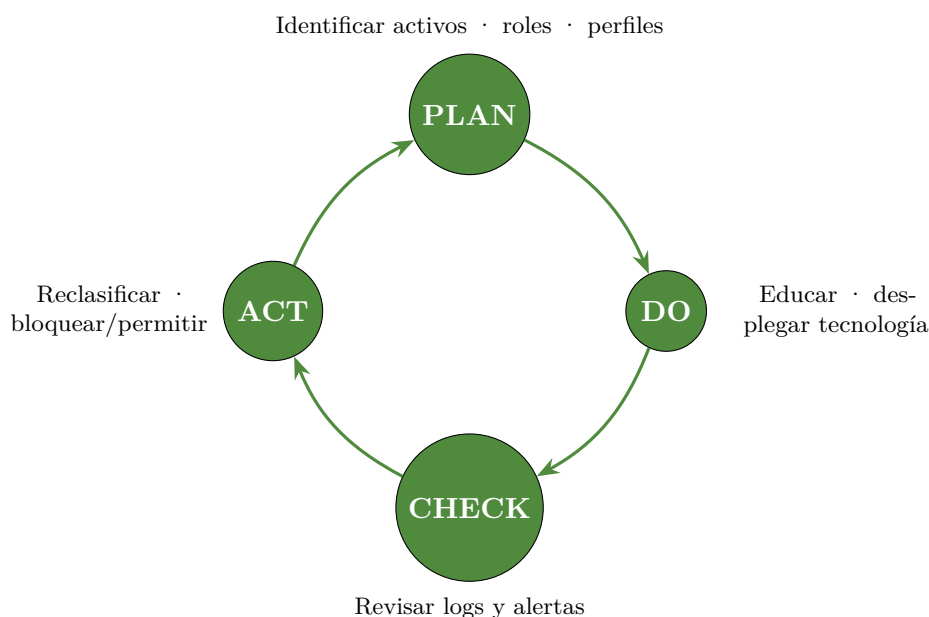
Data User. El individuo autorizado que efectivamente **accede a los datos** y hace algo con ellos.

6 Descubrimiento (Discovery)

Identificar y «contar» los datos que se van a proteger. No todo es un activo y no todo dato requiere asegurarse, así que primero hay que **clasificar** y luego decidir.

6.1 Clasificación de los datos

La diapositiva la presenta como un ciclo **PLAN** → **DO** → **CHECK** → **ACT**:



- **Planificar:** identificar los *activos*, identificar los *roles* sobre esos datos (quién controla cada dominio — los *data roles*) y definir *perfiles de acceso* (algunos no requieren autorización; otros más protegidos).
- **Ejecutar:** *educar* a todos los involucrados sobre la clasificación de los datos y quién tiene potestad sobre cada uno; *desplegar la tecnología* que permita protegerlos (herramientas, políticas y perfiles de acceso).
- **Monitorear:** revisar *logs y alertas* para verificar que no se vulnere el acceso a datos que no corresponden.
- **Reaccionar:** si se detectan desvíos, *reclasificar y bloquear o permitir* según corresponda (un dato crítico puede pasar a no crítico y viceversa).

6.2 El mismo dato en distintos estados

El mismo dato puede pasar por distintos **estados**, formatos, medios y tecnologías, en distintas ubicaciones (hoy los data centers están distribuidos por el mundo). Las regulaciones definen lineamientos para **cada estado por separado**. Habitualmente se hablaba de dos estados (*en reposo* y *en tránsito*), pero hay un tercero importante (*en uso*).

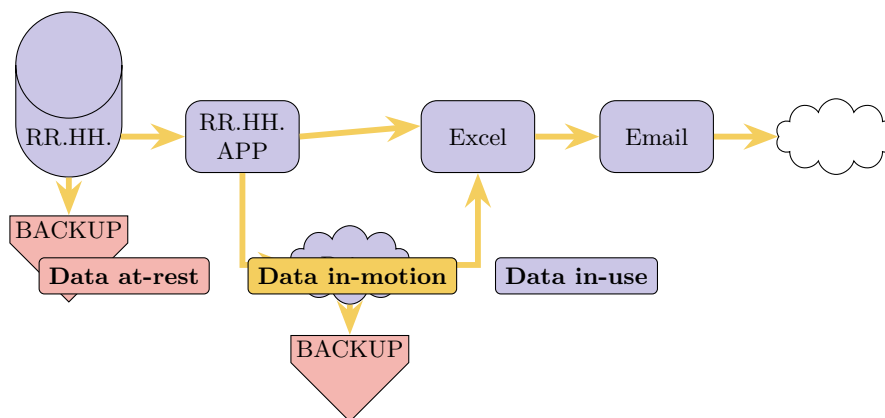
Los tres estados del dato

Data at-rest (en reposo). El dato está quieto, no se mueve ni se procesa. Ej.: una base de datos, un backup, una hoja de Excel, un objeto en un bucket S3.

Data in-motion (en movimiento/tránsito). El dato se mueve de una ubicación o estado a otro, generalmente por la red (también un pendrive, o cuando una app le pide un dato a otra y el dato sale de la base hacia el programa).

Data in-use (en uso). El dato está siendo procesado/utilizado por una aplicación, un servidor o una persona (transformándolo, calculando algo con él, etc.).

Sobre el mismo flujo de datos del problema inicial, cada componente está en alguno de los tres estados:



6.3 Data Inventory

Data Inventory

Identifica y **registra todos los datos críticos**: su ubicación, su uso, su clasificación y los responsables de cada uno. Sirve de **guía de referencia** para la toma de decisiones, el diseño de la seguridad y la aplicación de políticas.

No alcanza con «proteger todos los datos y listo»: los datos se necesitan para procesamiento, análisis y para que distintas personas los usen en distintos formatos. Por eso conviene inventariarlos: saber que existen, cómo deben clasificarse y de qué forma se pueden usar. El ciclo de inventario es: *Engage the business* → *Collect the information* → *Build the inventory* → *Create classifications* → *Use the inventory*.

Desafíos del Data Inventory

- **Costo de mantenerlo actualizado**: cambian los tipos de datos y, sobre todo, los **flujos de los datos** (la slide lo resalta en negrita). Cada vez que aparece, cambia o desaparece un dato, hay que actualizarlo.
- **Costo de inventariar**: descubrir nuevos tipos de datos es caro, especialmente en organizaciones muy grandes (hay que barrer cómo opera toda la empresa).
- **Falta de educación en su uso**: si la gente no avisa que generó datos nuevos, no se le saca provecho al inventario.
- **Son datos sensibles**: el propio inventario debe protegerse bajo las mismas reglas.
- **Complejo para la dinámica de las nuevas empresas**: queda rápidamente desactualizado.

6.4 Data Labeling (etiquetado)

Como alternativa al inventario centralizado surgió el **data labeling**.

Data Labeling

Busca inventariar los datos **dentro de los datos mismos** (como *metadata*): el dato lleva su propia clasificación. **Descentraliza** el inventario, pero permite que las etiquetas **circulen con los datos**. Simplifica las reglas de protección y monitoreo.

- Es **más flexible y realizable** que el inventario tradicional: el sistema que genera el dato ya le asigna su etiqueta.

- **No es un proceso estandarizado:** cada sistema debe *traducir* las etiquetas de un medio a otro. La organización puede normalizarlo internamente («todos los que manejen este tipo de datos sensibles aplican la política del labeling»).
- La mayoría de los sistemas modernos permiten crear etiquetas/metadata donde guardar esta información.

Ejemplo: AWS Tag Policy

Una política de IAM de AWS otorga acceso a un objeto S3 sólo si el objeto tiene cierta etiqueta. Es la materialización de la idea de *control de acceso basado en etiquetas*:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Principal": { // <-- SUJETO
        "AWS": [ "arn:aws:iam::111122223333:role/JohnDoe" ]
      },
      "Effect": "Allow",
      "Action": ["s3:GetObject", "s3:GetObjectVersion"],
      "Resource": "arn:aws:s3::DOC-EXAMPLE-BUCKET/*", // <-- OBJETOS
      "Condition": {
        "StringEquals": {
          "s3:ExistingObjectTag/environment": "production" // <-- ETIQUETA
        }
      }
    }
  ]
}
```

- **Sujeto:** el Principal (el rol JohnDoe).
- **Objetos:** el Resource (los objetos del bucket).
- **Etiqueta:** la Condition sobre la tag `environment = production`.

7 Protección (Protect)

Toda la preparación anterior (gobierno, descubrimiento, clasificación) sirve para **efectivamente proteger** los datos. Acá se ven las técnicas concretas.

7.1 Enforcement en tiempo de compilación (Compiler-time)

Enforcement (Compiler-time)

Asegura que el código cumple ciertas políticas de seguridad **antes de ser ejecutado**. Se hace en la fase de compilación, donde el compilador analiza el código fuente para detectar posibles violaciones (**análisis estático de código**). El compilador puede asegurar que los datos clasificados como confidenciales no se filtren a variables o zonas de memoria de menor seguridad.

Ejemplos de violaciones que se buscan detectar: imprimir contraseñas o datos sensibles en un log. El profesor aclara una errata de la slide: el ejemplo en Java es el `GuardedString` (la slide dice `SecureString`).

GuardedString vs. String en Java

Un `GuardedString` guarda el string **encriptado**: si alguien inspecciona la memoria en vivo, no lo va a poder leer (tendría que desencriptarlo). En cambio, una contraseña en un `String` clásico de Java se ve en **texto plano** examinando la memoria del proceso con una herramienta. El profe acota que el `GuardedString` es «bastante lento».

También ayudan las **herramientas de análisis de código estático**, que conectan con las metodologías *DevSecOps* vistas la clase anterior (meter la seguridad dentro del desarrollo).

7.2 Encriptación de datos en reposo (at-rest)

Los datos en reposo no se mueven; una de las medidas es **encriptarlos en el medio en que están**. Como esos datos después hay que recuperarlos, se usa encriptación (reversible). Aparecen varias alternativas de *dónde* se guardan las claves:

HSM (*Hardware Security Module*, FIPS 140-1 a 4). Hardware específico de seguridad (visto también en Autenticación) dedicado a proteger secretos —p. ej. las **claves simétricas**, que son muy sensibles porque con una sola se puede desencriptar un montón de datos. Es **anti-tamper**: no se puede vulnerar fácilmente. Además, **ofrece las operaciones de (des)encriptación dentro del propio hardware**, así uno nunca accede a la clave: la operación la hace el HSM.

Keystore. Forma de resguardar claves (con software asociado): se guardan todas las claves encriptadas con una **clave maestra**, y con esa clave se accede a las demás.

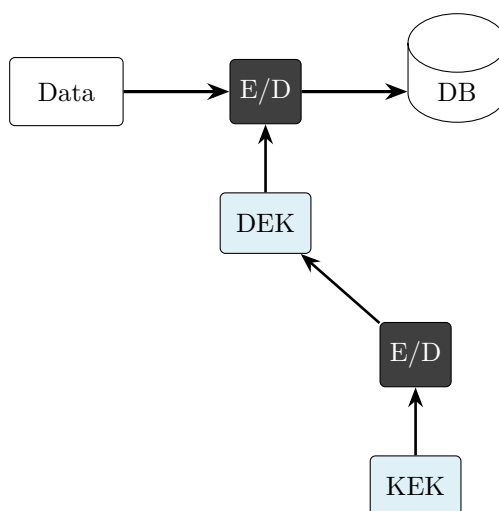
Security Appliance. Otro dispositivo dedicado a este resguardo (de la slide).

Esquema KEK-DEK (encriptación por capas)

KEK / DEK

DEK = *Data Encryption Key* (la clave que efectivamente cifra los datos).

KEK = *Key Encryption Key* (una clave que cifra a la DEK).

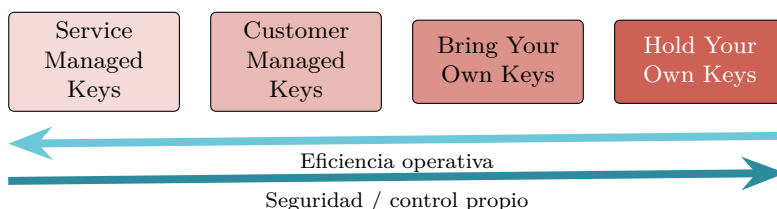


- **Más seguro:** con la KEK se cifra la DEK, que es la que termina cifrando los datos (dos capas).
- **Más flexible:** se puede **rotar la KEK** sin tener que reencriptar todos los datos, porque la DEK (la que cifró los datos) no cambia.
- **Contra:** es **más difícil de administrar** (implica una segunda capa de encriptación).

- Ejemplos de cifrado de almacenamiento en reposo: **EncFS** / **Loop-AES**, **EFS** (Windows), **FileVault** (macOS).
- La slide marca como problemas pendientes (×): **Data Remanence** (remanencia de datos) y **Secure Deletion** (borrado seguro).

En reposo, en la nube

La nube es **infraestructura de terceros**, en posesión del proveedor. La estrategia de encriptación es un *trade-off*: a más control sobre las claves, mayor complejidad y menor costo del lado del proveedor; a menos control, más eficiencia operativa pero mayor costo.



Cloud Workload con encriptación cloud-native (claves del lado del proveedor):

Service Managed Keys	El cliente no gestiona las claves. El proveedor decide cuándo rotarlas. No se puede acceder a las claves privadas ni usarlas para cifrar otros contenidos distintos de los que el proveedor decide. (Máxima delegación, máximo costo.)
Customer Managed Keys	El cliente gestiona las claves y decide cuándo rotarlas; no puede acceder a las claves privadas, pero puede encriptar lo que desee.
Bring Your Own Keys	El cliente trae sus propias claves (las genera y se las da al proveedor), las posee y decide cuándo rotarlas.

Cloud Workload con encriptación propia:

Hold Your Own Keys	El cliente cifra de su lado, antes de almacenar la info en el proveedor. Independiente del proveedor de nube (máximo control, mínima delegación).
---------------------------	--

¿De qué depende la elección? (pregunta de M. Gallardo en clase)

Depende 100 % de tres cosas: **(1)** qué querés hacer / cuánto te importa la seguridad; **(2)** cuánto querés delegar; y **(3)** tu posibilidad económica. Cuanto más a la izquierda (*Service Managed*), más responsabilidad tiene el proveedor ⇒ mayor costo, menos complejidad para vos. Cuanto más a la derecha (*Hold Your Own*), menos costo pero más complejidad propia (rotar y generar tus claves, protegerlas). Muchas empresas no son expertas en seguridad y terminan delegando cada vez más.

Ojo con la ubicación de los datos en la nube

Los proveedores tienen distintas **regiones**. Según cómo esté armada la distribución, los datos pueden quedar repartidos en **distintos países con regulaciones distintas** cada uno. Hay que tenerlo muy en cuenta.